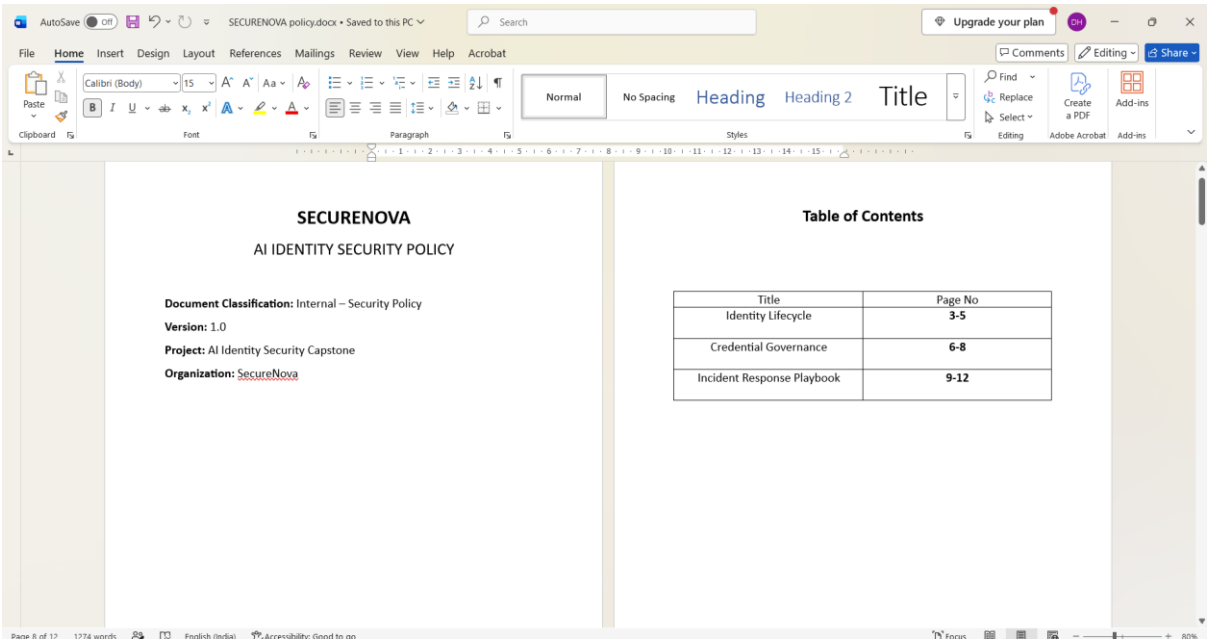
Policy and Presentation

Al Identity Security Policy :



SECURENOVA

AI IDENTITY SECURITY POLICY

Document Classification: Internal – Security Policy

Version: 1.0

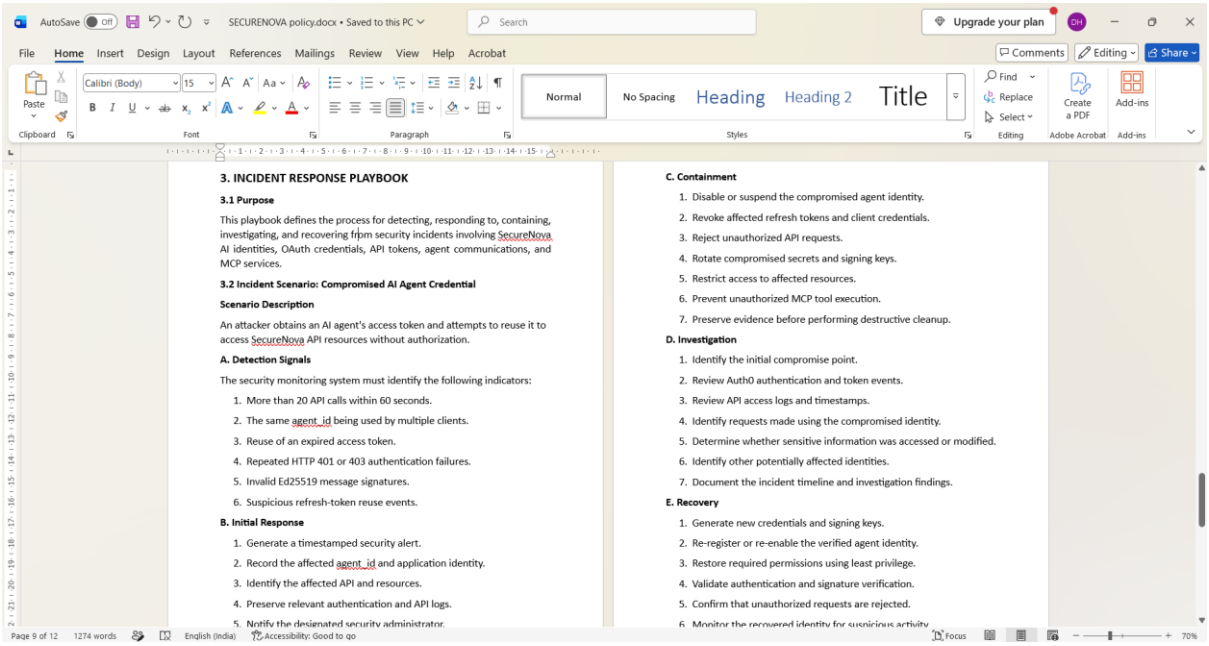
Project: AI Identity Security Capstone

Organization: SecureNova

Table of Contents

Title	Page No
Identity Lifecycle	**3-5**
Credential Governance	**6-8**
Incident Response Playbook	**9-12**

IR Playbook section:



3. INCIDENT RESPONSE PLAYBOOK

3.1 Purpose

This playbook defines the process for detecting, responding to, containing, investigating, and recovering from security incidents involving SecureNova AI identities, OAuth credentials, API tokens, agent communications, and MCP services.

3.2 Incident Scenario: Compromised AI Agent Credential

Scenario Description

An attacker obtains an AI agent's access token and attempts to reuse it to access SecureNova API resources without authorization.

A. Detection Signals

The security monitoring system must identify the following indicators:

1. More than 20 API calls within 60 seconds.
2. The same agent_id being used by multiple clients.
3. Reuse of an expired access token.
4. Repeated HTTP 401 or 403 authentication failures.
5. Invalid Ed25519 message signatures.
6. Suspicious refresh-token reuse events.

B. Initial Response

1. Generate a timestamped security alert.
2. Record the affected agent_id and application identity.
3. Identify the affected API and resources.
4. Preserve relevant authentication and API logs.
5. Notify the designated security administrator.

C. Containment

1. Disable or suspend the compromised agent identity.
2. Revoke affected refresh tokens and client credentials.
3. Reject unauthorized API requests.
4. Rotate compromised secrets and signing keys.
5. Restrict access to affected resources.
6. Prevent unauthorized MCP tool execution.
7. Preserve evidence before performing destructive cleanup.

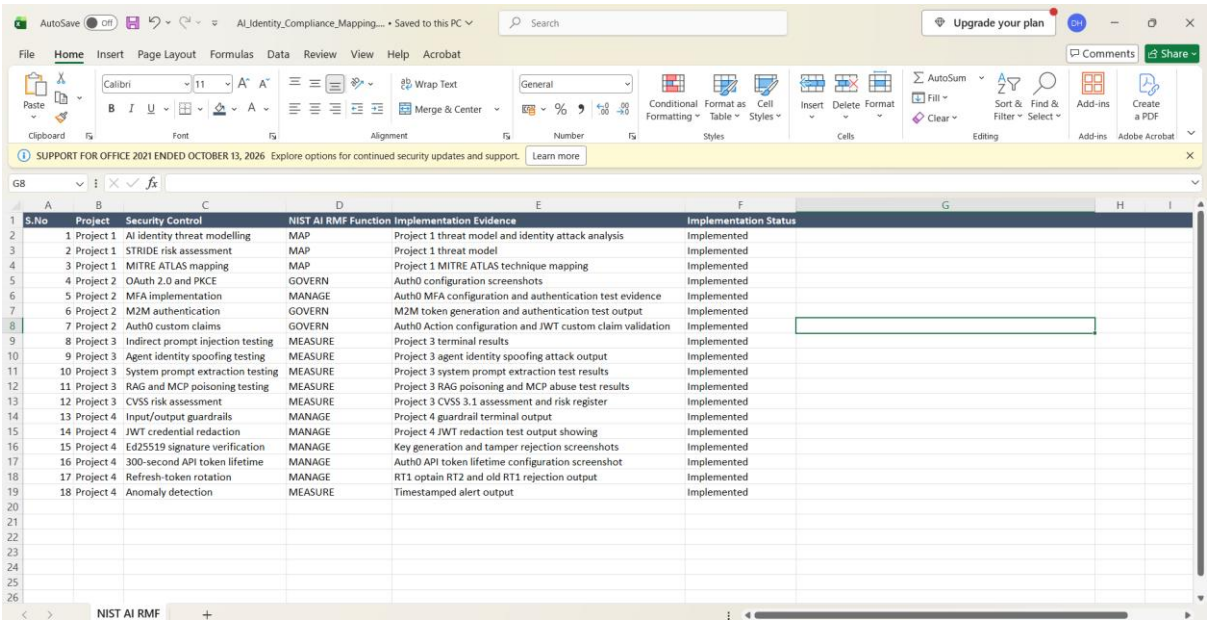
D. Investigation

1. Identify the initial compromise point.
2. Review Auth0 authentication and token events.
3. Review API access logs and timestamps.
4. Identify requests made using the compromised identity.
5. Determine whether sensitive information was accessed or modified.
6. Identify other potentially affected identities.
7. Document the incident timeline and investigation findings.

E. Recovery

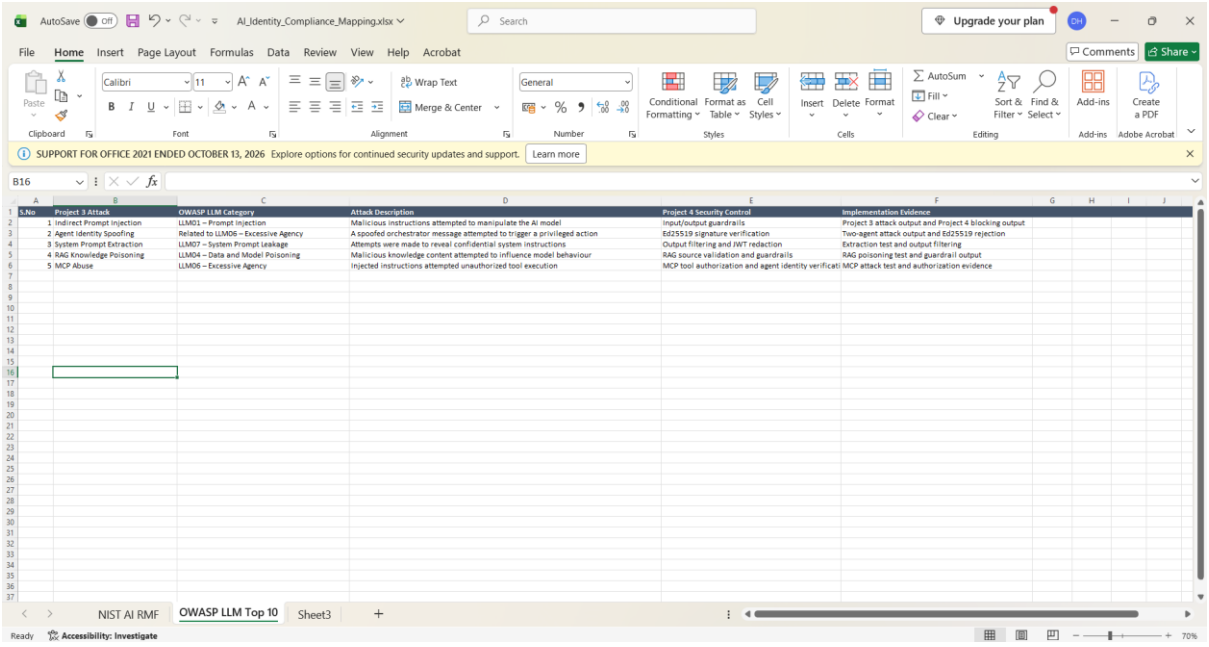
1. Generate new credentials and signing keys.
2. Re-register or re-enable the verified agent identity.
3. Restore required permissions using least privilege.
4. Validate authentication and signature verification.
5. Confirm that unauthorized requests are rejected.
6. Monitor the recovered identity for suspicious activity

NIST AI RMF tab:



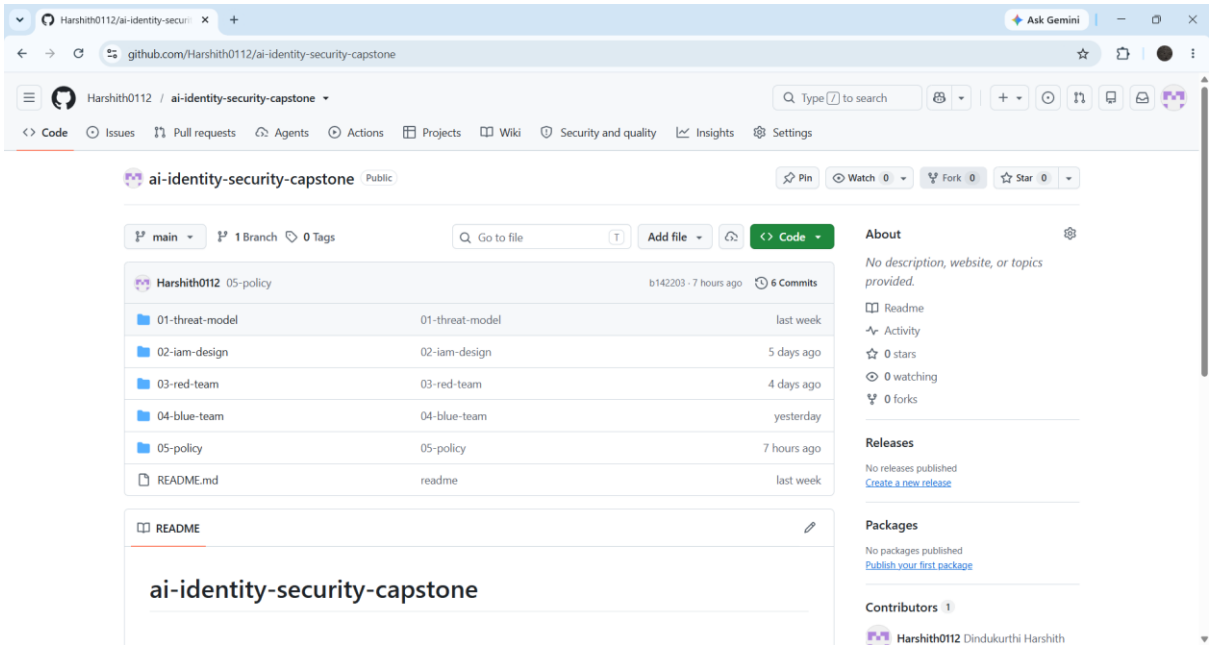
S.No	Project	Security Control	NIST AI RMF Function	Implementation Evidence	Implementation Status
1	Project 1	AI identity threat modelling	MAP	Project 1 threat model and identity attack analysis	Implemented
2	Project 1	STRIDE risk assessment	MAP	Project 1 threat model	Implemented
3	Project 1	MITRE ATLAS mapping	MAP	Project 1 MITRE ATLAS technique mapping	Implemented
4	Project 2	OAuth 2.0 and PKCE	GOVERN	Auth0 configuration screenshots	Implemented
5	Project 2	MFA implementation	MANAGE	Auth0 MFA configuration and authentication test evidence	Implemented
6	Project 2	M2M authentication	GOVERN	M2M token generation and authentication test output	Implemented
7	Project 2	Auth0 custom claims	GOVERN	Auth0 Action configuration and JWT custom claim validation	Implemented
8	Project 3	Indirect prompt injection testing	MEASURE	Project 3 terminal results	Implemented
9	Project 3	Agent identity spoofing testing	MEASURE	Project 3 agent identity spoofing attack output	Implemented
10	Project 3	System prompt extraction testing	MEASURE	Project 3 system prompt extraction test results	Implemented
11	Project 3	RAG and MCP poisoning testing	MEASURE	Project 3 RAG poisoning and MCP abuse test results	Implemented
12	Project 3	CVSS risk assessment	MEASURE	Project 3 CVSS 3.1 assessment and risk register	Implemented
13	Project 4	Input/output guardrails	MANAGE	Project 4 guardrail terminal output	Implemented
14	Project 4	JWT credential redaction	MANAGE	Project 4 JWT redaction test output showing	Implemented
15	Project 4	Ed25519 signature verification	MANAGE	Key generation and tamper rejection screenshots	Implemented
16	Project 4	300-second API token lifetime	MANAGE	Auth0 API token lifetime configuration screenshot	Implemented
17	Project 4	Refresh-token rotation	MANAGE	RT1 optain RT2 and old RT1 rejection output	Implemented
18	Project 4	Anomaly detection	MEASURE	Timestamped alert output	Implemented

OWASP LLM Top 10 tab with relevant categories mapped:

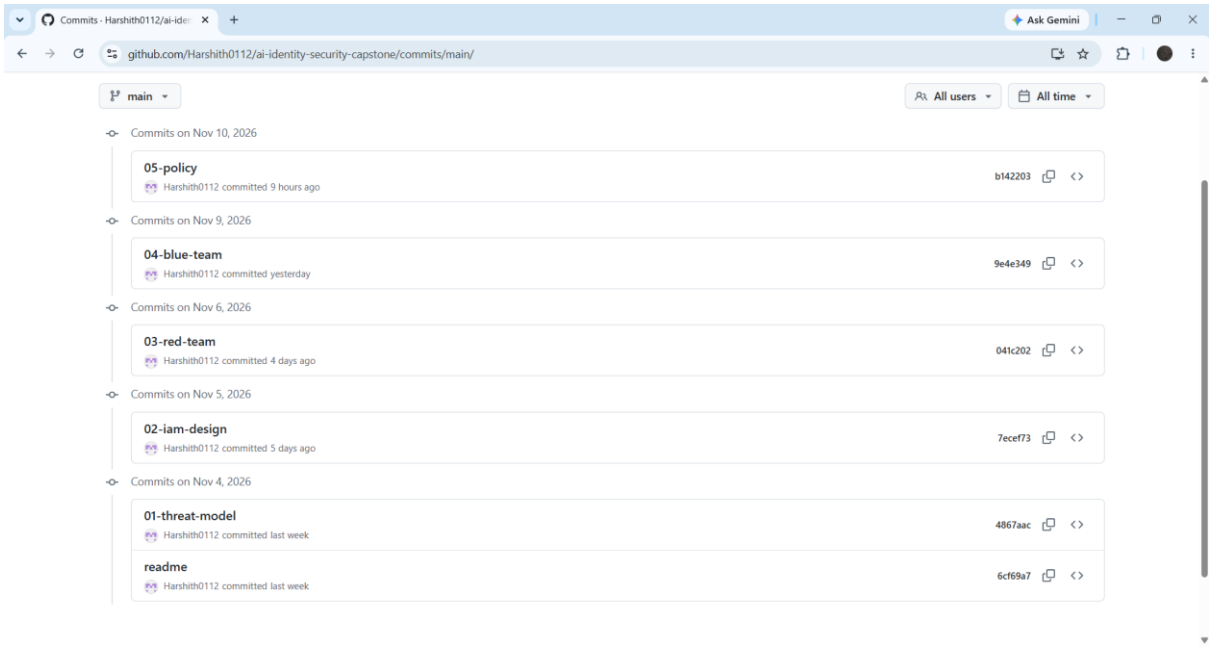


S.No	Project 3 Attack	OWASP LLM Category	Attack Description	Project 4 Security Control	Implementation Evidence
1	Indirect Prompt Injection	LLM01 – Prompt Injection	Malicious instructions attempted to manipulate the AI model	Input/output guardrails	Project 3 attack output and Project 4 blocking output
2	Agent Identity Spoofing	Related to LLM06 – Excessive Agency	A spoofed orchestrator message attempted to trigger a privileged action	Ed25519 signature verification	Two-agent attack output and Ed25519 rejection
3	System Prompt Extraction	LLM07 – System Prompt Leakage	Attempts were made to reveal confidential system instructions	Output filtering and JWT redaction	Extraction test and output filtering
4	RAG Knowledge Poisoning	LLM04 – Data and Model Poisoning	Malicious knowledge content attempted to influence model behaviour	RAG source validation and guardrails	RAG poisoning test and guardrail output
5	MCP Abuse	LLM06 – Excessive Agency	Injected instructions attempted unauthorized tool execution	MCP tool authorization and agent identity verificati	MCP attack test and authorization evidence

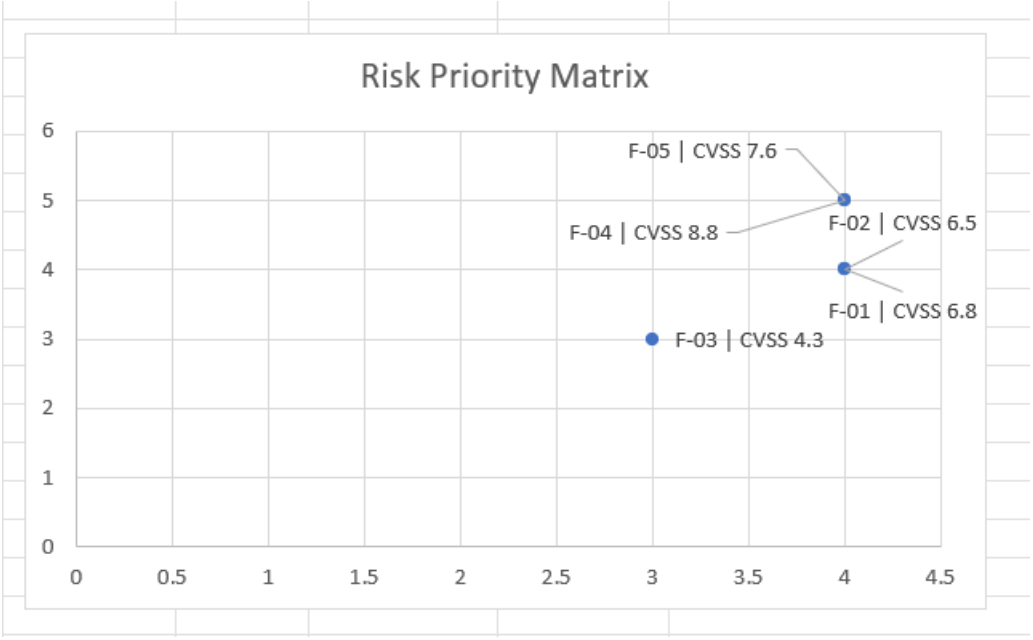
GitHub repository page:



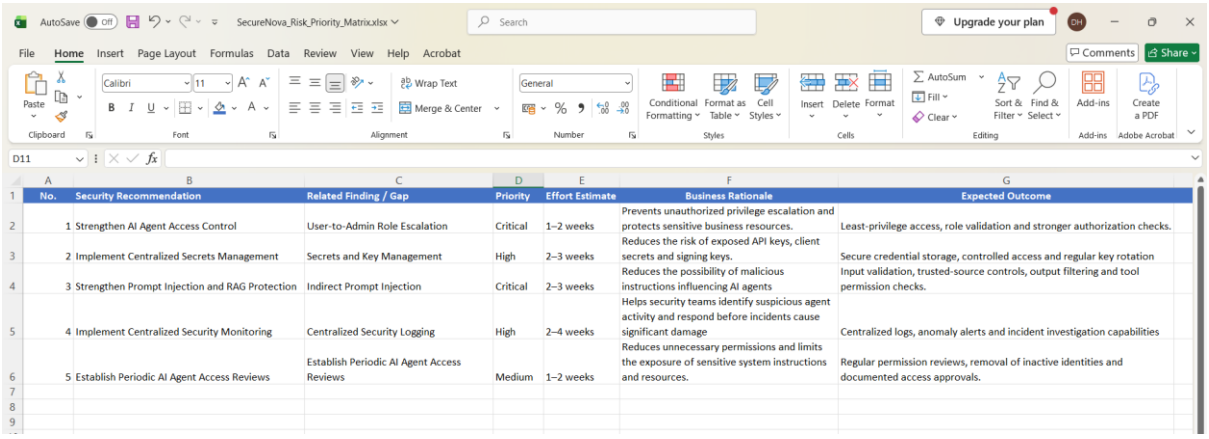
GitHub commit history:



Risk Priority Matrix:



Top 5 Recommendations with effort estimates and business rationale:



No.	Security Recommendation	Related Finding / Gap	Priority	Effort Estimate	Business Rationale	Expected Outcome
1	Strengthen AI Agent Access Control	User-to-Admin Role Escalation	Critical	1–2 weeks	Prevents unauthorized privilege escalation and protects sensitive business resources.	Least-privilege access, role validation and stronger authorization checks.
2	Implement Centralized Secrets Management	Secrets and Key Management	High	2–3 weeks	Reduces the risk of exposed API keys, client secrets and signing keys.	Secure credential storage, controlled access and regular key rotation
3	Strengthen Prompt Injection and RAG Protection	Indirect Prompt Injection	Critical	2–3 weeks	Reduces the possibility of malicious instructions influencing AI agents	Input validation, trusted-source controls, output filtering and tool permission checks.
4	Implement Centralized Security Monitoring	Centralized Security Logging	High	2–4 weeks	Helps security teams identify suspicious agent activity and respond before incidents cause significant damage	Centralized logs, anomaly alerts and incident investigation capabilities
5	Establish Periodic AI Agent Access Reviews	Establish Periodic AI Agent Access Reviews	Medium	1–2 weeks	Reduces unnecessary permissions and limits the exposure of sensitive system instructions and resources.	Regular permission reviews, removal of inactive identities and documented access approvals.